

v2.4.1 변경 요약

전체 소스 리뷰 후속 수정 · 릴리스 노트

항목	내용
버전	2.3.1 → 2.4.1
커밋	f4154f8 · chore(release): bump version to 2.4.1
일시	2026-08-24 10:06 KST
범위	41 files · +1,937 / -369
포함하지 않음	직전 커밋 ab2828f Quick Analysis 기능. 이 문서는 리뷰 수정만 다룬다.

이 릴리스는 측정 상수·정량 산식·kinase 판정을 바꾸지 않는다. 파이프라인 실행 게이트, 권한, 비밀 저장, SSE 인증, 관리 UI를 고친다.

1. 한눈에 보는 변경

구분	주제	요지
실행	Report 재실행	run-stage가 report_generation을 쓰고, 워커가 그 상태를 허용한다. queued는 계속 거부.
실행	동시 시작	주문 dispatch를 CAS로 잡고, 경쟁하면 409.
실행	Cancel / stale	체인 전체 Celery id revoke. Redis order_run_gen으로 이전 워커는 상태·로그를 쓰지 않음.
실행	RAG 컬렉션	start와 run-stage가 같은 해석 함수를 쓴다.
보안	경로 탈출	사용자 업로드 파일명을 디렉터리 밖으로 쓰지 못하게 한다.
보안	권한	주문 접근·쓰기·삭제·공유·관리 API를 역할에 맞게 잠근다.
보안	비밀	LLM API 키를 Fernet으로 저장. SSE는 JWT 대신 짧은 티켓.
보안	남용	rate limit이 실제로 429를 반환. 로그인 5회 실패 시 잠금.
입력	mzML / FASTA	mzML만으로 빈 TSV를 만들지 않음. 사용자 분석에서 FASTA는 선택.
UI	Reports / Logs	사이드바 링크가 실제 목록·로그 화면과 API를 가리킨다.
UI	관리 구역	비관리자가 /admin/*에 오면 /app으로 보낸다.

2. 파이프라인 실행

2.1. Report 단독 재실행

이전에는 report 재실행이 주문 상태를 queued로 두고, 워커는 그 값을 stale로 보고 건너뛰었다. 이제 API는 report_generation을 쓰고 워커 허용 집합에 그 값을 넣는다. queued는 이전 run의 stale task를 막기 위해 계속 거부한다.

대상: api-server/app/api/orders.py, workers/report_generation/tasks.py

2.2. 동시 start / run-stage

_claim_order_dispatch가 상태를 원자적으로 바꾼다. 이미 실행 중이면 409.

2.3. Cancel 이후 stale 워커

- cancel이 체인에 걸린 Celery task id를 모두 revoke한다.
- start / run-stage마다 Redis order_run_gen을 올린다.
- 워커는 generation이 다르면 DB 상태와 로그를 쓰지 않고 중단한다. (workers/common/run_control.py)
- Re-run UI는 고정 1.5초 대기 대신 cancel 상태를 폴링한다.

워커 프로세스가 즉시 죽는 것은 보장하지 않는다. 산출 수치는 바뀌지 않는다.

2.4. ChromaDB 컬렉션

주문 시작과 stage 재실행이 `_resolve_order_chromadb_collections`를 같이 쓴다. 저장된 컬렉션 id가 있으면 활성인 것만, 없으면 이전처럼 활성 컬렉션 전체를 쓴다.

3. 접근 제어와 역할

3.1. 주문 읽기 / 쓰기 / 삭제

- GET `/orders/{id}/status`, GET `/events/orders/{id}`도 주문 접근을 확인한다.
- 쓰기 경로는 `_require_write_access` → viewer는 403 (Viewer role is read-only).
- 채팅 저장·삭제, 사용자 주문 생성·설정 추론, compare 저장·리포트·채팅도 viewer를 막는다.
- 삭제는 `full_access` 공유자가 할 수 없다. 소유자 또는 admin만.

3.2. 공유

같은 사용자에게 다시 공유하면 409 (Already shared with this user). UI는 「이미 이 사용자와 공유되어 있습니다」. `order_shares`에 unique index `uq_order_share`를 맞춘다.

3.3. 관리·민감 API

영역	규칙
Articles	목록·삭제 등 민감 동작에 인증. 삭제는 admin.
Health / 컨테이너	관리 엔드포인트는 admin. SSE 로그는 <code>require_sse_role("admin")</code> .
Co-Scientist	admin / analyst만 쓰기. 주문 접근을 확인.
RAG / LLM	쓰기(생성·수정·삭제·pull)는 admin.
PTMQuant	잡 생성·파일 브라우저는 admin. 잡 조회는 소유자 또는 admin.
Chat	메시지를 남기기 전에 주문 존재와 접근을 확인.
Compare	저장·채팅 저장·PDF·리포트 생성은 양쪽 주문 접근 + viewer 차단.
프론트 /admin/*	admin이 아니면 /app으로 리다이렉트.

4. 비밀 · 전송 · 남용 방지

4.1. LLM API 키

평문 저장을 중단한다. `encrypt_secret` / `decrypt_secret` (`enc:v1:` + Fernet, 키는 `JWT_SECRET`의 SHA-256). 예전에 넣은 평문은 읽을 때 그대로 쓰고, 다시 저장할 때 암호화된다. 컬럼은 `VARCHAR(1024)`. 의존성 `cryptograph>=42.0.0`.

4.2. SSE 티켓

EventSource는 Authorization 헤더를 못 넣는다. 예전에는 URL에 JWT를 붙였다.

- POST `/api/events/ticket` → 120초짜리 티켓. Redis `sse_ticket:{ticket}` = user id.
- 프론트 `openEventSource()`가 연결마다 티켓을 받고 `?ticket=`만 붙인다.
- 적용: 주문 진행, PTMQuant 진행, 시스템 모니터 컨테이너 로그.
- 서버는 Bearer와 예전 `?token=`도 받는다. 프론트는 JWT를 URL에 넣지 않는다.

4.3. Rate limit

제한을 넘기면 로그만 남기고 통과하던 동작을 없앴다. 60초 300회를 넘으면 429. 예외: `/api/health`, `/api/version`, `/api/events/`, GET `/api/orders/{id}/status`. 로그인 실패 5회 / 5분이면 핸들러 전에 429.

4.4. PPTX

생성은 주문 쓰기 권한이 있어야 한다. 상태 조회의 공유 레벨 문자열을 오류로 보지 않는다. Redis `pptx_task:{order_id}:{task_id}`가 있을 때만 상태를 알려 주고, 다른 주문의 task id는 404.

5. 입력 · 사용자 흐름

항목	내용
업로드 경로	<code>_safe_upload_filename</code> + <code>_write_under_dir...</code> 등으로 입력 디렉터리 밖 기록을 막음.

mzML only	mzML만 올리면 빈 PR/PG TSV placeholder를 만들지 않음. Protein/peptide 그룹 파일이 있어야 함.
FASTA	사용자 New Analysis에서 FASTA는 선택. 플랫폼 reference는 /orders/reference-status로 확인.
계정 생성	생성 응답에 API가 만든 temporary_password를 보여 줌. 재발급은 reset_password: true.
Reports	GET /orders/reports + 실제 Reports 페이지. 사이드바가 연결.
Logs	GET /orders/pipeline-logs + 실제 Logs 페이지. 사이드바가 연결.

6. 이 커밋이 만지지 않은 것

- AUTH_ENABLED 기본값 (docker-compose / .env 기본은 꺼짐. 내부 사용자는 admin으로 동작).
- mzML → PTMQuant 자동 연결.
- 디버그 스크립트의 고정 비밀번호.
- Quick Analysis (ab2828f). 정량 산식, kinase 판정, 사전등록 임계.

7. 변경 파일

구역	파일
버전	VERSION
API · 주문/인증	orders.py, user_orders.py, auth.py, dependencies.py, main.py
API · 보안	core/security.py, middleware/security.py
API · 기능	chat.py, compare.py, events.py, health.py, llm.py, presentation.py, ptmquant.py, rag.py, articles.py, coscientist.py
모델	models/llm_model.py, pyproject.toml
프론트	App.tsx, Sidebar.tsx, useSSE.ts, lib/sse.ts, ShareOrderModal.tsx, NewAnalysis.tsx, OrderDetail.tsx, Reports.tsx, Logs.tsx, PTMQuant.tsx, SystemMonitor.tsx, CoScientistPage.tsx, CoScientistTab.tsx
워커	run_control.py, progress.py, db_update.py, preprocessing / rag / report / watchdog tasks.py
원장	docs/implementation_log.md (실행 게이트 2건, append-only)

8. 확인

배포 후 /api/version은 2.4.1을 반환한다. 프론트 번들에 POST /api/events/ticket 호출이 들어 있다. 이 문서는 커밋 f4154f8의 워킹트리 diff를 기준으로 작성했다.